

CYBER BOOTCAMP
UNIVERSIDAD CARLOS III DE MADRID

INTRODUCCIÓN A LA CIBERSEGURIDAD

Medidas de seguridad. Controles

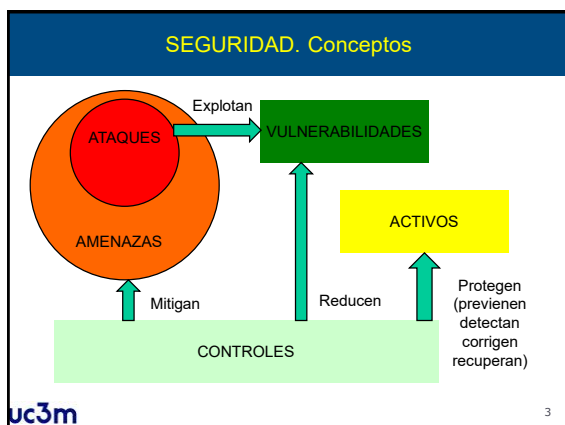
PRESENTADO POR: ENTIDAD: MÓDULO:
Arturo Ribagorda Garnacho Universidad Carlos III de Madrid Básico

CONTROL

CONTROL
Medida que **modifica** un riesgo, normalmente para disminuirlo.

Puede ser: administrativos; técnicos; de gestión o legales.

Se usa como sinónimo de **medida de seguridad, salvaguarda o contramedida**).



RIESGO

Concepto vinculado con la posibilidad de que una amenaza explote una, o varias, vulnerabilidades de un activo o grupo de activos de información, y causen un daño (impacto) a una organización¹

1. UNE-EN ISO/IEC 27000:2021

uc3m

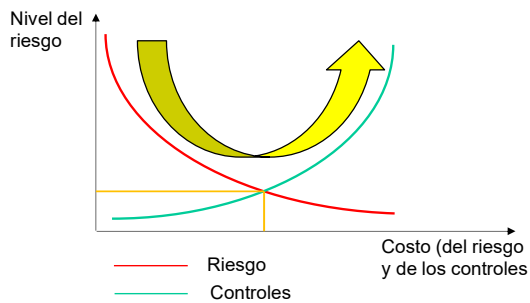


PRINCIPIO DE PROPORCIONALIDAD

Las medidas de seguridad y su aplicación deben ser **proporcionales** a la **naturaleza** de los datos, a los riesgos a los que están expuestos éstos y los sistemas de información que los tratan, y al **estado** de la tecnología

uc3m

SGSI. Tratamiento del riesgo (equilibrio costo-riesgo)

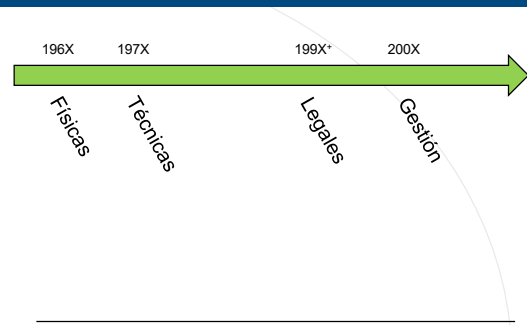


uc3m

MEDIDAS DE SEGURIDAD (CONTROL). Según actuación

- Prevención
Minimiza probabilidad de ocurrencia de un ataque
- Detección
Minimiza propagación del ataque
- Corrección
Minimiza el daño de un ataque
- Recuperación
Minimiza las consecuencias de un ataque
- Resiliencia
Capacidad de un sistema para recobrar su estado inicial cuando ha cesado la perturbación a la que había estado sometido

MEDIDAS DE SEGURIDAD (CONTROLES). Según naturaleza



9

MEDIDAS DE SEGURIDAD. Físicas

- Sistemas detección y extinción de incendios
- Ídem de inundaciones
- Control de acceso físico
- Sistemas de alimentación ininterrumpida
- ..

uc3m

10

MEDIDAS DE SEGURIDAD. Técnicas

- Identificación y autenticación
MFA, biometría,...
- Control de accesos
- Confidencialidad
Anonimización, cifrado
- Integridad
Cifrado, *hash*
- No repudio
Firma digital

uc3m

11

SECRETS AND LIES. BRUCE SCHNEIER

If you think technology can solve your security problems, then you **don't understand** the problems and you **don't understand** the technology

uc3m

Secrets and Lies. Bruce Schneier

The mantra of any good security engineer is: **“Security is a not a product, but a process.”** It's more than designing strong cryptography into a system; it's designing the entire system such that all security measures, including cryptography, work together

uc3m

MEDIDAS DE SEGURIDAD. Gestión

- Sistemas de gestión de la seguridad de la información
 - ISO, Cobit, NIST CSF, ..
- Normas de evaluación y certificación de la seguridad
 - *Common Criteria/Common Methology*, ITSEC/ITSEM

uc3m

NIVELES DE CONFIANZA

EAL1 EAL2 EAL3 EAL4 EAL5 EAL6 EAL7

uc3m

MINISTERIO DE DEFENSA
CENTRO NACIONAL DE INTELIGENCIA
CENTRO CRIPTOLÓGICO NACIONAL
ORGANISMO DE CERTIFICACIÓN

REF: 2004-4-MIF-148 v2
Dilección: Público
Fecha: 30.07.2007

Creado: CERT2
Revisado: TÉCNICO
Aprobado: JEFEAREA

INFORME DE CERTIFICACIÓN

Expediente: 2004-4 DNle v1.13

Referencias:

EXT-30 **Solicitud de Certificación Tarjeta CERES (DNle).**
EXT-343 **Informe Técnico de Evaluación del Producto Tarjeta "DNle" v1.13.** TFC/TRE/204/2001/MIT/A07, CESTI-MITA, ed.1.0, 29/03/2007.
CCRA **Arrangement on the Recognition of Common Criteria Certificates in the field of Information Technology Security**, mayo 2000.
DIRF **Directiva 1999/93/CE del Parlamento Europeo y del Consejo**, de 13 de diciembre de 1999, por la que se establece un marco comunitario para la firma electrónica.
CWA14169 **"Dispositivos seguros de creación de firma (EAL4+)" v1.05 Tipo 3 - Marzo 2002.**

uc3m

INTRODUCCIÓN A LA FAMILIA ISO/IEC 27XXX

VISIÓN GENERAL Y TERMINOLOGÍA

UNE-EN ISO/IEC 27000:2021. Sistema de gestión de la seguridad de la información (SGSI). Visión de conjunto y vocabulario

uc3m

21

INTRODUCCIÓN A LA FAMILIA ISO/IEC 27XXX

ESPECIFICACIÓN DE REQUISITOS

- UNE-EN ISO/IEC 27001:2017. Sistemas de Gestión de la Seguridad de la Información (SGSI). Requisitos
- ISO/IEC 27006:2020. Requisitos para organismos que realizan auditorías y certificación de los SGSI

uc3m

22

INTRODUCCIÓN A LA FAMILIA ISO/IEC 27XXX

DIRECTRICES GENERALES

- UNE-EN ISO/IEC 27002:2017. Código de buenas prácticas para la Gestión de la Seguridad de la Información
- ISO/IEC 27003:2017, *Information security management system implementation guidance*
- ISO/IEC 27004:2016, *Information security management —Monitoring, measurement, analysis and evaluation*

uc3m

23

PRINCIPALES AGENTES DE LA CIBERSEGURIDAD

CONSEJO DE SEGURIDAD NACIONAL

- Consejo Nacional de Ciberseguridad

PRESIDENCIA DEL GOBIERNO

- Departamento de Seguridad Nacional (DSN)



uc3m

24

PRINCIPALES AGENTES DE LA CIBERSEGURIDAD

MINISTERIO DE DEFENSA

- Mando Conjunto del Ciberespacio (MCCE)
- Centro de Sistemas y Tecnologías de la Información y las Comunicaciones (CESTIC)
- Centro Criptológico Nacional/Centro Nacional de Inteligencia (CCN/CNI)

MINISTERIO DE ASUNTOS ECONÓMICOS Y TRANSFORMACIÓN DIGITAL

MINISTERIO DEL INTERIOR

MANDO CONJUNTO DEL CIBERESPACIO¹



uc3m

1. O M 10/2013. Creación MCC de las FF.
AA.

MCCE. Misiones

Planear y ejecutar acciones de
ciberdefensa militar

Responder **oportuna, legítima y
proporcionadamente** en el ciberespacio

Concienciar, formar y adiestrar

uc3m

CENTRO CRIPTOLÓGICO NACIONAL



uc3m

CCN-CERT (CERT Gubernamental nacional español)

Capacidad de Respuesta a incidentes del CCN
(www.ccn-cert.cni.es)

- Creación: 2006
- Responsabilidad: Sistemas de la **Administración Pública** y de empresas de **interés estratégico**
- Misión: **Centro de alerta y respuesta nacional**

uc3m

31

SISTEMAS DE ALERTA TEMPRANA (SAT). Sondas Sistema SAT-INET¹



uc3m

1. CCN-CERT 20 ANIVERSARIO. Incidentes

PRINCIPALES AGENTES DE LA CIBERSEGURIDAD

MINISTERIO DE DEFENSA

MINISTERIO DE ASUNTOS ECONÓMICOS Y
TRANSFORMACIÓN DIGITAL

- Instituto Nacional de Ciberseguridad (INCIBE)

MINISTERIO DEL INTERIOR

uc3m

INSTITUTO NACIONAL DE CIBERSEGURIDAD



INSTITUTO NACIONAL DE
CIBERSEGURIDAD



uc3m

INSTITUTO NACIONAL DE CIBERSEGURIDAD

- Sociedad Estatal

Secretaría de Estado para la SI y la Agenda Digital (M.
de Asuntos Económicos y Transformación Digital)

- Ámbito

Ciudadanos y empresas

- Objetivos:

Proteger a los usuarios de Internet y las TIC

Establecer mecanismos de prevención y reacción

Promover la cultura de la seguridad de la información

Minimizar el impacto de incidentes de seguridad

uc3m

PRINCIPALES AGENTES DE LA CIBERSEGURIDAD

MINISTERIO DE DEFENSA

M. AA EE Y TRANSFORMACIÓN DIGITAL

MINISTERIO DEL INTERIOR

- Centro Nacional de Protección de Infraestructuras Críticas (CNPIC)
- Oficina de Coordinación de Ciberseguridad
- Departamento Contra el Ciberdelito
- Unidad de Investigación Tecnológica (UIT)

uc3m

37

OFICINA DE COORDINACIÓN DE CIBERSEGURIDAD



uc3m

40

OFICINA DE COORDINACIÓN DE CIBERSEGURIDAD

- Contacto nacional para el intercambio de información con la UE y Estados miembros
- Canal de comunicación entre los **CSIRT nacionales de referencia y la SES**
- **CSIRT del M.I** de apoyo a la Policía Judicial (CSIRT-MIR-PJ)
- Autoridad competente en la seguridad de las redes y sistemas para recibir notificaciones de seguridad de operadores críticos



uc3m

ACTORES CIBERSEGURIDAD

PREVENCIÓN	ESDEF-CERT
PROTECCIÓN	CCN-CERT
	INCIBE-CERT
RESPUESTA	CERT-SOC (Otros)

PERSECUCIÓN



uc3m



INTRODUCCIÓN A LA CIBERSEGURIDAD

Medidas de seguridad. Controles

PRESENTADO POR: ENTIDAD MÓDULO
 Arturo Ribagorda Garnacho Universidad Carlos III de Madrid Básico